Zaguik: Zero-Knowledge Attestation for Privacy-Preserving LLM Governance

Jan Aguiló Plana
Universitat Pompeu Fabra
Carrer de Roc Boronat, 138, Barcelona
jan.aguilo01@estudiant.upf.edu

Vanesa Daza
Universitat Pompeu Fabra
Carrer de Roc Boronat, 138, Barcelona
vanesa.daza@upf.edu

***Resumen*—Regulators increasingly require evidence-backed assurances about how AI systems handle sensitive information. We present Zaguik, a privacy-preserving attestation pipeline that proves, in zero knowledge, that a large language model (LLM) response passed a personally identifiable information (PII) filter, without revealing either the response text or the filtering model. The system generates an LLM response, applies a PII detection policy, and produces a zk-SNARK using EzKL over the detector inference. The proof exposes only a public commitment (a hash) to the exact response, binding verification to the delivered output while keeping its contents private; filtering logic and outputs remain private. We provide a runnable reference implementation, discuss practical setup requirements and ONNX compatibility constraints, and outline how such proofs can support GDPR-aligned auditing and transparent AI governance.**

***Index Terms*—Jornadas, Ciberseguridad**

Tipo de contribución: *Investigación en desarrollo*

I. Introduction

Artificial intelligence (AI) systems that process personal data are increasingly subject to enforceable obligations beyond voluntary transparency pledges. Regulations such as the European Union's General Data Protection Regulation (GDPR) and emerging AI acts require evidence-backed assurances about how systems handle sensitive information, comply with safety requirements, and respect data-subject rights. For large language models (LLMs) deployed in customer-facing or regulated settings, demonstrating that outputs do not leak personally identifiable information (PII) is both a legal necessity and a trust requirement. Auditors and regulators need not only policies on paper but verifiable guarantees that those policies are actually applied in production.

Today, verifying that a provider applies a PII filter to LLM outputs typically requires the auditor to trust the provider's claims or to inspect the outputs and the filtering logic directly. If the auditor sees the raw outputs, privacy is compromised; if the provider must disclose the filtering model or its parameters, intellectual property and competitive concerns arise. This tension leaves a gap: there is no cryptographically sound way to prove that a given output was filtered for PII without revealing either the output or the internals of the filter. Zero-knowledge proofs (ZKPs) address this need by allowing one party (the prover) to convince another (the verifier) that a statement is true without revealing the underlying data or computation. Applied to AI pipelines, ZKPs can attest that a specific computation was performed (e.g., that a PII filter was applied and that its result indicated no PII) while keeping the model and the actual text private.

In this work we describe and implement Zaguik, a system that produces such a verifiable, privacy-preserving attestation for LLM outputs. The pipeline works as follows: (1) an LLM generates a response to a user prompt; (2) a PII filter (in our reference implementation, a regex-based detector) is applied to the output; (3) if the output passes the filter, a SHA256 hash of the output is computed and the output is encoded as input to a circuit; (4) a zk-SNARK proof is generated using EzKL, attesting that the filter was applied and that the circuit output corresponds to a "clean" result, with the proof bound to the hash of the response; (5) any verifier holding the hash and the proof can confirm that filtering was correctly applied without ever seeing the text or the filter internals. The proof thus ties verification to the exact delivered output while preserving confidentiality. This approach illustrates how cryptographic attestation can support transparent AI governance: compliance and audit can be based on verifiable proofs rather than on trust alone, and both user privacy and provider confidentiality can be preserved. We provide a runnable reference implementation and discuss practical considerations.

II. Related Work

III. Methodology

The core contribution of this work is the *cryptographic attestation pipeline*: we show how to produce a zk-SNARK proof that a given string was passed through a certified check, with the proof bound to a commitment to the output and with no disclosure of the text or the checker's internals. The PII filter is the policy we attest to; its design is deliberately simple so that the focus remains on the proof system. Below we describe the architecture, the filter used in the current implementation, the encoding of outputs for the circuit, the proof system and visibility semantics, and the setup, proof, and verification procedures.

III-A. System Overview

The pipeline has two phases: a *filtering phase* and a *proof phase*. In the filtering phase, a user prompt is answered by an LLM (in our implementation we use DistilGPT-2); the response is then checked by a PII detector. Only if the detector reports that the text contains no PII do we enter the proof phase. There we encode the (clean) output as input to a circuit that models the same filtering logic, generate a zk-SNARK proof over that circuit using EzKL, and output a proof bound to a public commitment (hash) of the response. A verifier who receives the proof and the commitment can check that the filtering computation was correctly applied to the committed

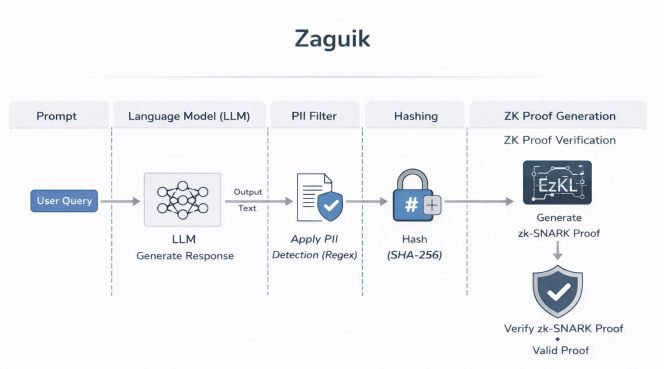

Figura 1. End-to-end workflow: from user prompt and LLM response through PII filtering to proof generation and verification.

output, without learning the text or the internal parameters of the filter. The LLM itself is out of scope of the proof: we attest only that a given string was passed through the certified PII filter and passed.

III-B. Formal Statement and Security Model

We formally define the statement that Zaguik proves and clarify the visibility of data in the zero-knowledge setting.

III-B0a. Notation.: Let $y \in \{0,1\}^*$ denote the output string generated by the LLM. Let $H(\cdot)$ be a cryptographic hash function (SHA256 in our implementation). Let F denote the PII filtering policy. Let C be the certified arithmetic circuit that implements F. Let L be the fixed input length used for encoding. Let $\mathrm{Enc}_L(y)$ denote the byte-level encoding of y, truncated or zero-padded to length L.

III-B0b. Public and Private Data.: The zero-knowledge proof distinguishes between public inputs and private witness:

- **Public input:**
  - $h = H(y)$, a commitment to the LLM output.
  - The verification key associated with circuit C.
- **Private witness:**
  - The full LLM output string y.
  - Its encoded representation $x = \mathrm{Enc}_L(y)$.
  - The internal witness values required to execute circuit C.

The verifier learns only the commitment h and the proof. The underlying text y and the internal circuit execution remain hidden.

III-B0c. Language Definition.: The proof system attests membership in the following NP language:

$$\mathcal{L} = \{\, h \mid \exists y \text{ such that } H(y) = h \wedge C(\mathrm{Enc}_L(y)) = 1 \,\}.$$

In other words, $\mathcal{L}$ contains all hash values for which there exists a corresponding text that both matches the hash and passes the certified PII filtering circuit.

III-B0d. Zero-Knowledge Statement.: The prover demonstrates, in zero knowledge, that:

$$\exists y \text{ such that } H(y) = h \wedge C(\mathrm{Enc}_L(y)) = 1.$$

Informally, this means:

> "There exists an LLM output y that corresponds to the public hash h, and when processed by the certified PII filtering circuit C, the result is `PASS`."

III-B0e. Scope of the Guarantee.: The proof guarantees correct execution of the certified filtering circuit on the committed output. It does not guarantee that the filtering policy is complete or semantically sufficient, nor does it make claims about the internal behavior of the LLM. The guarantee is limited to enforcement integrity: that the specific circuit C was correctly executed on a text consistent with the public commitment.

III-C. PII Filtering and Policy

We need a concrete policy that decides whether an output is "clean" so that the circuit can attest to it. In the current implementation we use only a *regex-based* PII filter: it checks for common patterns such as email addresses, US Social Security numbers, phone numbers, and credit-card-like sequences. This filter is used in plain to gate which outputs may receive a proof. The same logic is reflected in a small, circuit-friendly ONNX model (e.g., a minimal network that encodes a conservative check over the encoded bytes), which we compile with EzKL so that the proof attests that this deterministic check was run and passed. The cryptographic pipeline is agnostic to the choice of filter: once a detector is expressible as an ONNX model that EzKL can compile, the same proof and verification flow applies. For this work, the regex-based filter suffices to demonstrate and evaluate the ZK attestation.

III-D. Encoding and Circuit Input

The LLM output is a string. To feed it into the circuit we encode it in a fixed-size form. For our regex-derived circuit we use a byte-level encoding: the UTF-8 representation of the string is truncated or zero-padded to a fixed length $L = 128$, and each byte is normalized to $[0,1]$ by dividing by 255. The result is a matrix of shape $[1, L]$ that becomes the single input tensor to the ONNX circuit. The *same* string that passed the plain PII check is the one committed to and fed into the circuit, so the proof is tied to the exact delivered output.

We also compute a SHA256 hash of the output for logging and for binding the proof to the response in APIs or protocols. Inside the proof system, the circuit input is committed (e.g., via a hash) so that the verifier sees only this commitment; they can then ensure that the proof refers to the same output the user or system holds.

III-E. Proof System and Visibility Semantics

We use EzKL to compile the ONNX model into an arithmetic circuit and to produce zk-SNARK proofs (succinct, non-interactive arguments of knowledge). The security and privacy guarantees depend on how inputs, outputs, and parameters are exposed.

The circuit is configured so that the *input* is only revealed as a commitment (hash): the prover commits to the encoded output string, and the verifier learns this commitment but not the underlying bytes, so the LLM response stays private while the proof is bound to a specific output. The *output* of the circuit is made available to the verifier so they can check that it indicates "pass" (e.g., zero PII score). The filter *parameters*

are fixed in the circuit and not revealed; the verifier only learns that the same certified circuit was executed. Together, these choices ensure that we prove "this committed output was run through the certified PII filter and passed" without leaking the text or the filter internals.

III-F. Setup and Proof Generation

Setup is performed once per circuit (e.g., per ONNX model and settings). The ONNX is used to generate the proof-system settings and to compile an arithmetic circuit; a KZG structured reference string (SRS) is required and can be obtained from a trusted source or generated locally for testing. With the compiled circuit and SRS, key generation yields a proving key and a verification key.

For each clean LLM output we wish to attest, we encode it as input data, compute the witness for the circuit, and run the prover to produce the final proof. The proof, the verification key, and (in deployment) the public commitment to the output are what the verifier needs.

III-G. Verification

Verification is deterministic: given the proof, the verification key, the settings, and the SRS, the verifier runs the verification algorithm and accepts if and only if the proof is valid. No secret data is required. If the verifier holds a hash of the LLM output (e.g., SHA256 or the in-circuit commitment), they can confirm that the proof applies to that exact output, so that attestation is non-detachable and binding.

III-H. Implementation and Reproducibility

Our reference implementation is in Python. The PII filter is regex-based in the current experiments. The cryptographic pipeline (regex-derived ONNX export, encoding, setup, proof generation, and verification) is implemented as a single scriptable workflow. The default configuration builds the small regex-derived ONNX, runs setup, and then generates and verifies proofs for a given text string. All steps are documented so that the pipeline can be reproduced and extended; integrating a more expressive PII model would require an ONNX export that is compatible with the proof system backend.

IV. Results

We ran the full pipeline (DistilGPT-2, regex PII filter, proof generation and verification) with a fixed prompt and varied the maximum number of tokens generated by the LLM to assess how proof size and timings behave with respect to output length. All runs used the same regex-derived ONNX circuit and the same one-time setup. Setup was performed once; the reported setup costs are from a single run and include generating settings, compiling the circuit, obtaining the SRS, and key generation. Table I summarizes these one-time costs. Table II reports, for each output length (max tokens), the proof size, total proof generation time, witness generation time, and verification time.

Proof size remains stable at 21.4 and 21.5 KB across all output lengths, as expected for a fixed circuit: the zk-SNARK proof size depends on the circuit structure, not on the input length. Proof generation time is dominant (roughly 8–13 s in these runs); witness generation stays under 55 ms and verification under 180 ms. The reported circuit corresponds to a lightweight regex-based filter compiled to ONNX; more complex neural PII detectors would increase circuit size and proof cost. These results indicate that zero-knowledge attestation of LLM output filtering is computationally feasible for small fixed circuits, with proof sizes around 21 KB and verification times below 200 ms, making third-party verification lightweight relative to proof generation.

Tabla I
ONE-TIME SETUP COSTS (REGEX PII ONNX).

Step	Time (s)
Settings generation	0.07
Circuit compilation	0.03
SRS retrieval	0.00
Witness (setup)	0.07
Key generation	12.28
Total	12.45

Tabla II
PROOF SIZE AND TIMINGS VS. LLM OUTPUT LENGTH (MAX TOKENS).

Max tokens	Proof size (KB)	Proof gen. (s)	Witness (ms)	Verify (ms)
30	21.4	9.85	41	180
50	21.4	9.83	42	149
100	21.5	8.56	40	151
200	21.4	8.58	41	142
300	21.4	9.72	39	170
500	21.4	13.08	53	157

V. Discussion

V-A. Interpretation of Results

The experimental results demonstrate that zero-knowledge attestation of LLM output filtering is computationally feasible using a small, fixed circuit. Proof size remains constant (approximately 21 KB) across varying output lengths, confirming that zk-SNARK size depends on circuit structure rather than input data. This aligns with the theoretical properties of KZG-based proving systems such as Halo2.

Proof generation time is the dominant cost (approximately 8–13 seconds in our experiments), while verification remains lightweight (below 200 ms). This asymmetry is desirable in governance settings: proof generation occurs on the provider side, whereas verification can be performed by auditors, regulators, or third parties with minimal computational overhead. Witness generation time remains negligible compared to proving, further indicating that the cryptographic proving step is the primary computational bottleneck.

Because the circuit operates on a fixed-size input encoding ($L = 128$ bytes), LLM outputs are truncated or padded before hashing and filtering. As a result, the constraint system remains constant across experiments, explaining the stability of proof size and runtime.

V-B. Governance and Security Implications

The proposed pipeline illustrates a shift from trust-based enforcement to cryptographically verifiable enforcement. In conventional deployments, external parties must trust that providers correctly apply safety or privacy filters to LLM outputs. Alternatively, verification requires exposing either the generated output or the filtering logic, creating privacy and intellectual property risks.

By contrast, our approach enables a third party to verify that a filtering policy was applied correctly to a specific output (bound via a cryptographic hash) without revealing the output itself or the internal logic of the filter. This supports a form of privacy-preserving auditability aligned with regulatory requirements such as GDPR, particularly in contexts where outputs may contain sensitive information.

The mechanism is policy-agnostic: although we instantiate it with a PII regex filter, the same architecture can, in principle, attest to toxicity detection, policy compliance, or other post-processing safeguards.

V-C. Limitations

Several limitations must be acknowledged.

First, the filtering policy implemented in this prototype is lightweight and regex-based. While sufficient to demonstrate feasibility, it does not reflect the complexity of modern neural PII detection systems. Attempts to integrate larger ONNX-based NER models revealed compatibility constraints within current ZKML tooling. More expressive models would likely increase circuit size and proof cost.

Second, the circuit operates on fixed-length inputs. Very long responses would require batching, segmentation, or recursive proof composition to remain practical.

Third, the system proves correct execution of the filtering policy, not the adequacy of the policy itself. A weak or incomplete PII detector can still be correctly executed and proven. Thus, zero-knowledge attestation ensures enforcement integrity, but not semantic completeness.

These limitations define important boundaries for interpreting the results and guide future extensions.

VI. Conclusions

We presented Zaguik, a privacy-preserving attestation pipeline that proves, in zero knowledge, that an LLM output has passed a PII filtering policy without revealing either the output or the filtering logic. Using EzKL and a fixed ONNX-based circuit, we demonstrated that proof sizes remain constant and verification costs remain low, while proof generation is computationally manageable for backend deployment.

These results indicate that zero-knowledge proofs can serve as a practical mechanism for verifiable AI governance, enabling auditability without exposure. Beyond standalone LLM responses, such attestation mechanisms could be integrated into agentic workflows, where language models trigger actions, access tools, or store intermediate state. In these settings, cryptographic guarantees that each intermediate output satisfies policy constraints could provide a foundational layer for privacy-preserving and accountable AI systems.

Future work will explore integration with neural PII detectors, scalable handling of longer outputs, and deployment within broader AI compliance frameworks.